الجامعة السورية الخاصة
كلية هندسة الذكاء الاصطناعي
قسم هندسة البرمجيات ونظم المعلومات الذكية

السمينار الأول

منصة لتقييم الضوابط الأمنية وإدارة الأدلة في مستودعات GitHub

Security Controls Assessment and Evidence Management Platform for GitHub Repositories

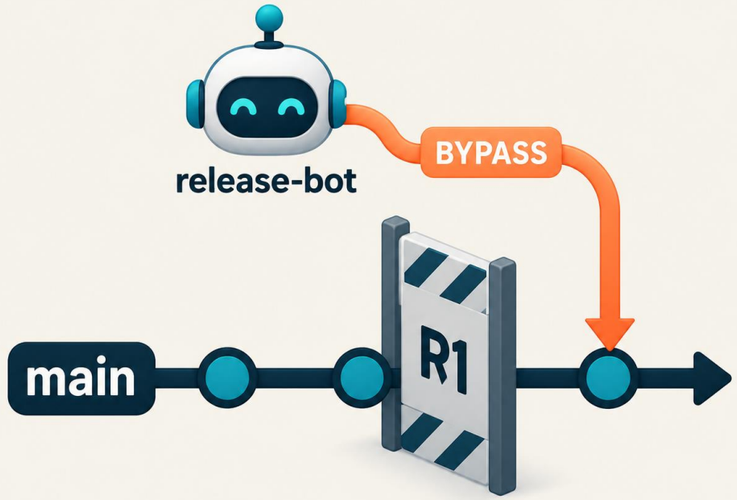
إعداد عمر فوزي العكله
إشراف الدكتور كادان جمعة
المهندس عبدالرحمن عرار



2026–2027

المشكلة وهدف المشروع

تقييم ما يستطيع كل طرف تنفيذه ثم إصلاح المخالفة



الاستثناء يفتح مسارًا حول هذه القاعدة

تتداخل القواعد والاستثناءات في تحديد الحماية

قد يوقف إصلاح عام عملية تحتاجها المؤسسة

نربط الحكم بدليل ونولد خطة للحالات المدعومة

المستخدمون مسؤول المؤسسة والمقيّم والمراجع

الهدف تقييم مفسر ومعالجة قابلة للمراجعة وإعادة تحقق

نطاق المشروع

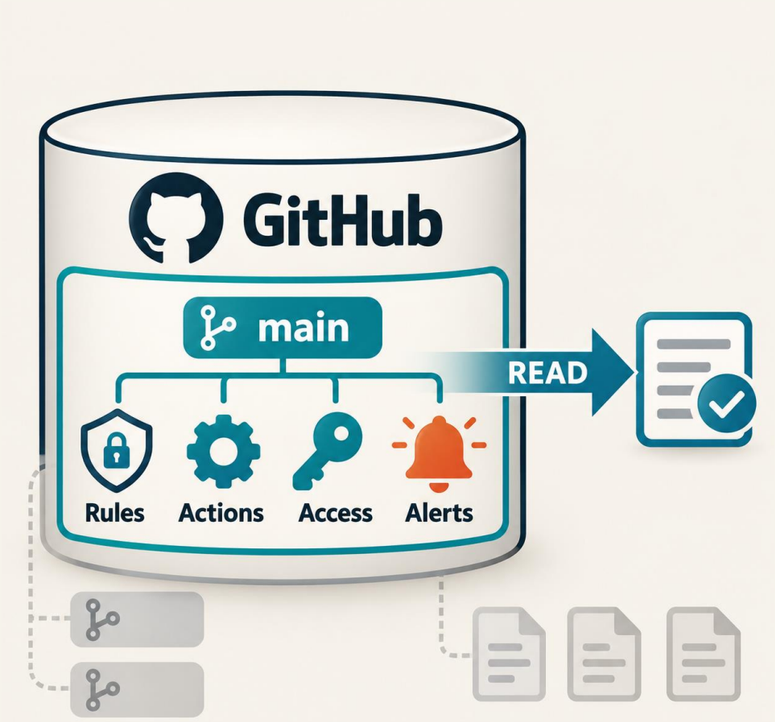
مستودعات GitHub المصرح بها، بدءًا بالفرع الافتراضي

إعدادات الحماية والأتمتة وبيانات الخدمات الأمنية

20 فحصًا أساسيًا و 4 مشروطة بتوافر الخدمة والصلاحية

تطبيق المسؤول للتعديل يدويًا ثم إعادة التحقق

فحص الشيفرة الشامل و RAG خارج الإصدار الأول



نقرأ البيانات ضمن النطاق والصلاحيات المتاحة

خدمات المنصة

سبع خدمات و 28 متطلبًا وظيفيًا رئيسيًا

تحديد النطاق وسياسة المؤسسة

الاتصال مع GitHub وجمع البيانات

التقييم وإظهار أسباب النتائج

تحليل أثر القواعد والاستثناءات

توليد خطط الإصلاح ومراجعتها

المعالجة وإعادة التحقق والتاريخ

الأدلة والتقارير

الفحوص الـ 24 جزء من أحد المتطلبات الرئيسية



فحص ودليل وخطة ثم إعادة التحقق

الفحوص المستهدفة

كتالوج محدد من 24 فحصًا

حماية الفروع والاستثناءات — 10

PR والموافقات والفحوص المطلوبة ومصدرها

إعدادات GitHub Actions — 7

الصلاحيات ومصادر Actions وسلوك Forks

إعدادات المستودع والوصول — 3

مفاتيح النشر بصلاحية الكتابة، وظهور المستودع، وأمان Webhooks

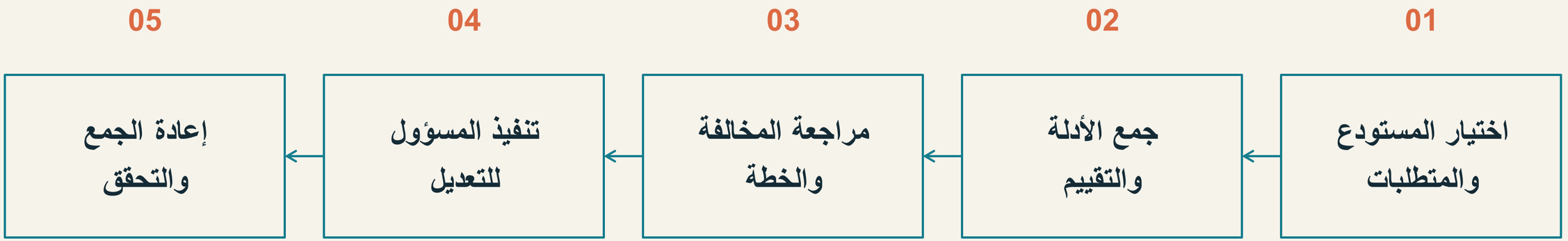
أدلة الخدمات الأمنية — 4

الأسرار وحماية الدفع والتنبيهات وحداثة التحليل

الفحوص الأربعة الأخيرة مشروطة بتوافر الخدمة وصلاحية القراءة

رحلة الاستخدام

تستمر المتابعة حتى إعادة التحقق من المعالجة



نحتفظ بأدلة التقييم السابقة عند إعادة التحقق

الدليل ونتيجة التقييم

كل حكم مرتبط بالمصدر والوقت والنطاق

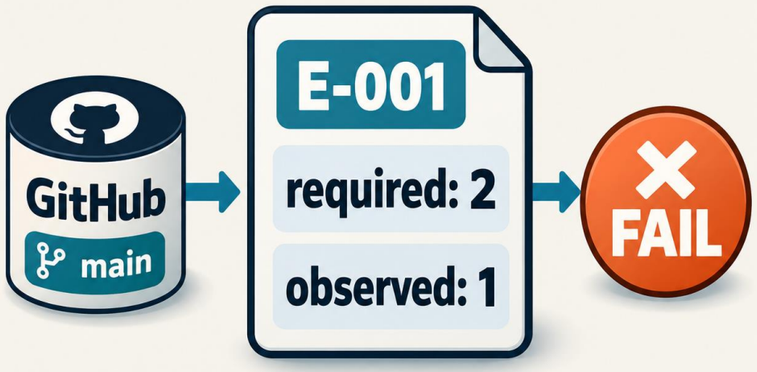
مستوفى أو غير مستوفى بحسب السؤال المحدد

غير محسوم عند نقص معلومات لازمة

غير منطبق مع تسجيل السبب

إعادة التحقق تنشئ تقييمًا جديدًا وتحفظ السابق

NIST SP 800-53A مرجع لطرق الفحص والاختبار



مثال السياسة تطلب موافقتين والإعداد يفرض واحدة:

دراسات إصلاح السياسات

CloudFix · 2026

نسخة أولية لإصلاح سياسة AWS

سياسة AWS وطلبات سماح ومنع هي المدخلات

تحديد الخطأ ثم اقتراح LLM ثم تحقق SMT

237 إصلاحًا كاملًا من 282 مقابل 136 للمرجع

عشرة طلبات لكل سياسة؛ وخمس دورات كحد أقصى

عند 50 :طلبًا سبعة إصلاحات كاملة فقط

دقة تصنيف الطلبات تختلف عن نسبة الإصلاح الكامل

:استفادتنا نحدد العمليات والتعديلات ونختبر السماح والمنع قبل قبول الخطة

IAM-PolicyRefiner · 2024

بحث منشور في OOPSLA لتقليل الصلاحيات

سياسة AWS وسجل استخدام؛ ثم تعديلات محلية

اختبر 11 دورًا وسجلات ثلاثة أشهر

يضيق الصلاحيات مع حفظ الوصول المرصود

سجل قصير قد يمنع عمليات مشروعة لاحقة

امتداد للطلبات الممنوعة؛ والتمثيل يؤثر في النتيجة

ضمانات الدراسة مشروطة بفضاء التعديل والافتراضات

دراسات إدارة النتائج والأدلة وأمن الأتمتة

الدراسة والسنة	المشكلة وطريقة المعالجة	التجربة والنتيجة
Security Flama 2024 · ICSE-SEIP	يوحد التقارير ويجمع المتشابه يحفظ المصدر وتاريخ الظهور يفصل اختفاء النتيجة عن حلها	ست عشرة نقطة جمع في مشروعين تجميع خفّض العدد بثلثين على الأقل أثر المعالجة اختلف بتبني الفريق
Continuous Security Compliance 2024 · ESEM	راجع تحديات أربع دراسات صنف اثنين وستين تحديًا وصاغ خريطة بحث للأتمتة	التغير قد يكسر المتطلبات الأمنية توثيق الأدلة مكلف واختبارها محدود لم يختبر أداء منتج مكتمل
Revisiting Security Practices 2025 · ICPC	GHAST / 4 categories 18,938 Workflows / 5,246 Repos نسختان زمنيتان للعينة نفسها	غياب التصريح بالصلاحيات تراجع 84.7% (2022) / 74.9% (2024) 33,362 findings / 2024 نتائج كاشف، وليست هجمات مثبتة

إدارة النتائج والأدلة أساس المنصة؛ والمساهمة المتخصصة هي إصلاح قواعد GitHub

مقارنة خدمات الأنظمة

النظام	نطاق العمل	تخصيص السياسة	النتائج والمتابعة
Scorecard	الفروع والأتمتة وممارسات المستودع	معايير وعتبات قابلة للضبط	درجات وأسباب JSON
Checkov	إعدادات المستودع وملفات الأتمتة	سياسات مخصصة Python / YAML	تقارير فحص SARIF
Legitify	المؤسسة والأعضاء والمستودعات والأتمتة	سياسات مخصصة OPA	مخالفات حسب الشدة JSON / SARIF
Minder	مستودعات واعتماديات وطلبات دمج	Profiles Rego / JQ	حالة السياسة وتنبيه وإصلاح
DefectDojo OSS	نتائج أدوات الفحص المستوردة	تهيئة إدارة النتائج وقبول المخاطر	حالات معالجة ومرفقات وتقارير وتاريخ نتائج
مشروعنا مستهدف	أربعة وعشرون فحصًا وتحليل وإصلاح محدود	سياسة المؤسسة وأهداف الأطراف	دليل وتاريخ وإعادة تحقق وتقرير مراجعة

قدرات الأنظمة من الوثائق؛ وظائف منصتنا الإنتاجية ما زالت مصممة

مقارنة آلية الإصلاح

المسار	القواعد والاستثناءات	مدخل السياسة أو الهدف	ناتج المعالجة	تنفيذ التعديل
Scorecard	تجميع حماية الفرع	عتبات فحوص	نتائج وإرشادات	إرشاد للمسؤول
Checkov	حماية تقليدية في المسار المفحوص	سياسات فحوص	تقرير الفحص	إرشاد للمسؤول
Legitify	فحص القواعد والاستثناءات	سياسات مخصصة Rego	إرشاد للمخالفة	إرشاد للمسؤول
Minder OSPS-AC-03.01	بحسب القاعدة المعتمدة	معاملات السياسة Profile	قالب جاهز وإصلاح قابل للتخصيص	PR / REST
DefectDojo OSS	من أداة الفحص المصدرة	عقد أهداف الأطراف لم يُتحقق منه	إرشاد النتيجة المستوردة	متابعة المعالجة
محركنا نموذج محلي	نموذج محلي لتراكب الطبقات	قائمة سماح ومنع لكل طرف	بحث محدود وكلفة معلنة	يدوي بعد المراجعة

المقارنة للمسارات المراجعة؛ التخصيص ممكن والتفوق المقاس لم يثبت

المساهمة الهندسية المقترحة

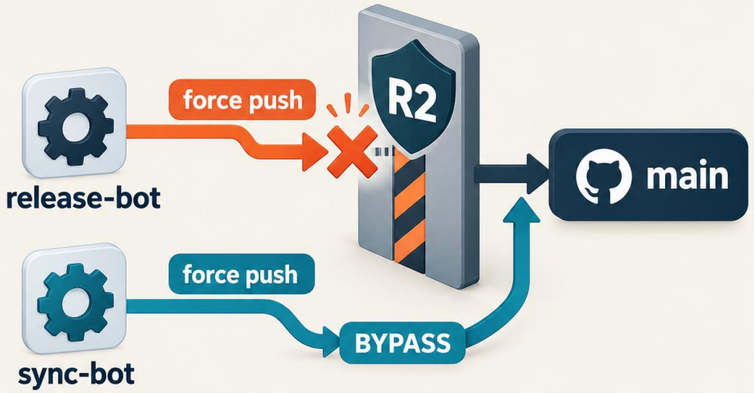
إصلاح قواعد GitHub المتراكبة وفق أهداف الأطراف

المؤسسة تحدد ما يسمح به وما يمنع لكل طرف

المحرك يحسب أثر القواعد المتراكبة والاستثناءات

يرفض الخطط التي تخالف شرطًا معلنًا

يعرض التعديل وسببه وحدود صلاحيته



مبدأ الإصلاح له أعمال سابقة؛ التفوق العملي يحتاج تقييمًا مستقلًا

نمنع الدفع القسري لطرف ونحفظه للطرف المصرح له

مثال الإصدار والمزامنة

R1 تشترط PR وتمنع الدفع القسري وتستثني البرنامجين

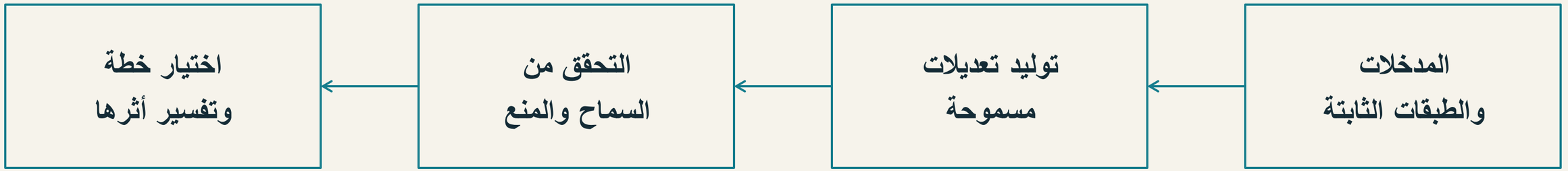
العملية	المطلوب	قبل الإصلاح	بعد الإصلاح
تحديث الإصدار الطبيعي	السماح	مسموح	مسموح
الدفع القسري للإصدار	المنع	مسموح	ممنوع
الدفع القسري للمزامنة	السماح	مسموح	مسموح
تحديث المطور المباشر	المنع	ممنوع	ممنوع
طلب دمج معتمد للمطور	السماح	مسموح	مسموح

نضيف R2 لمنع الدفع القسري مع استثناء المزامنة وحدها

مثال داخل النموذج المحلي مع افتراض تحقق بقية الشروط

كيف يولد المحرك الإصلاح

محرك حتمي يبحث ضمن تعديلات وحدود معلومة



نستبعد المدخلات الناقصة والخطط المخالفة للشروط

الكلفة حسب عدد الكتابات ثم القواعد الجديدة ثم تغييرات الحقول

الحد المحلي كتابتان والحتمية وحدها لا تثبت صحة التفسير

النتائج المحلية وحالة الإنجاز

خطط إصلاح	7
صحيحة أصلًا	1
بلا خطة ضمن كتابتين	4
متطلبات متناقضة	1
بيانات ناقصة	1
خارج الدعم	2

تعادل عدد الكتابات مع المرجع اليدوي الصحيح في الحالات الثماني

المنجز النطاق والدراسة والمقارنة والتصميم والنموذج المحلي

القادم تحقق GitHub حي وأول مسار كامل؛ التطبيق وجامع البيانات لم ينفذا

16

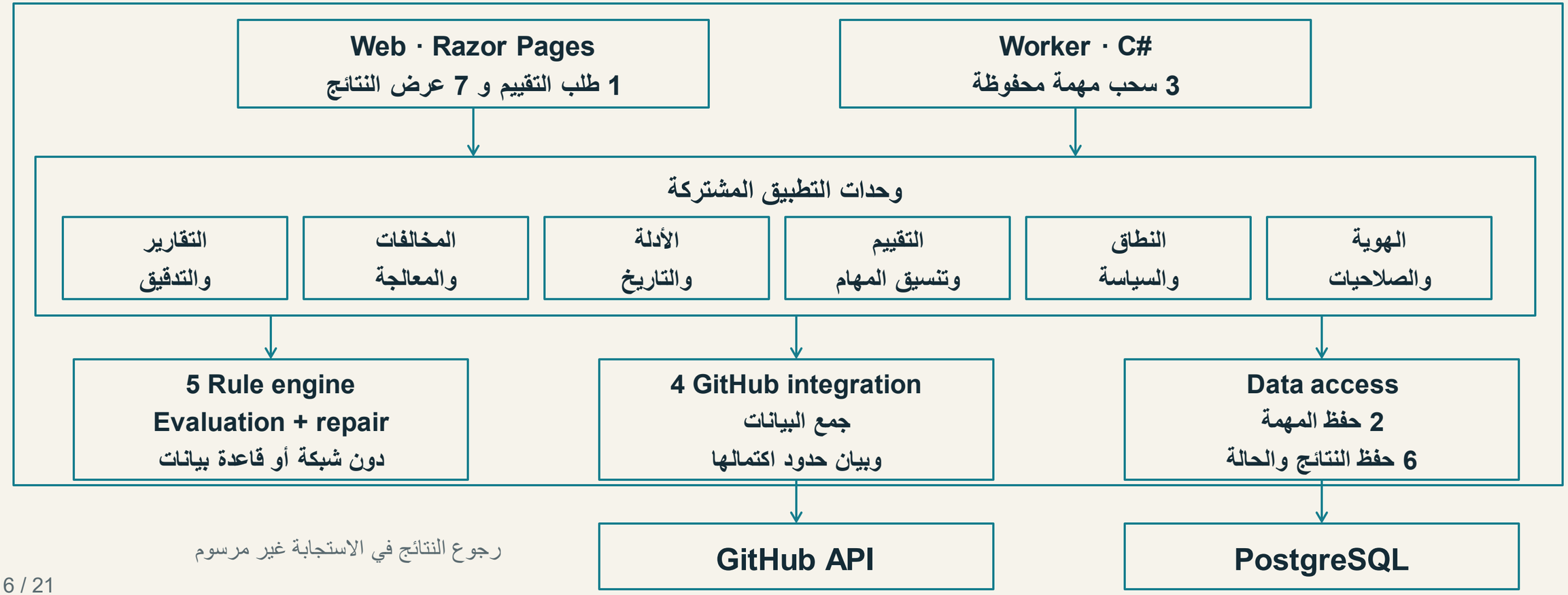
حالة مختبرية مصممة

نموذج Python محلي

معمارية المنصة

Modular Monolith بمنطق مشترك ومهام خلفية محفوظة

السهم من المستدعي إلى المكوّن المستدعى والأرقام لمسار مهمة واحدة



رجوع النتائج في الاستجابة غير مرسوم

اختيار التقنيات والمعمارية

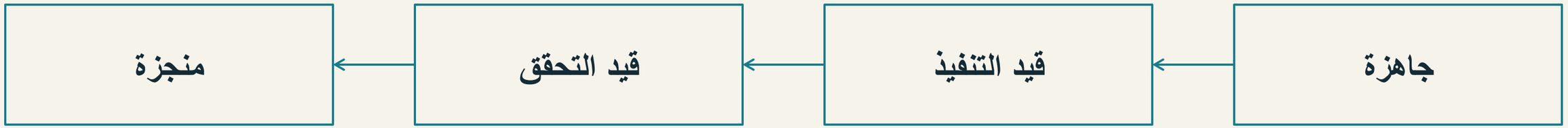
ASP.NET Core 10 LTS / C#	منطق المنصة والمحرك بلغة واحدة
Razor Pages / Bootstrap	واجهة متكاملة تكفي لمسار التقييم
EF Core / Npgsql / PostgreSQL	علاقات ومعاملات لحفظ النتائج والأدلة
Worker / durable jobs	مهام مصممة للاستمرار بعد انتهاء طلب الويب

تطبيق واحد يسهل التشغيل والنشر لوظائف تعتمد على بيانات مشتركة

المقابل نشر موحد وعزل أعطال أقل و Python مرجع للتجربة فقط

طريقة التطوير

تطوير تكراري وتزايدي باستخدام Kanban



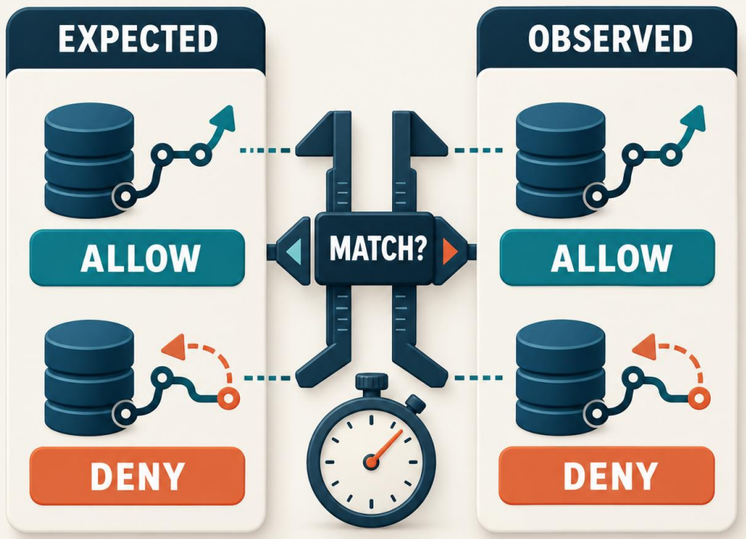
نبدأ بمهمة رئيسية واحدة ونراجع ناتج كل زيادة

الزيادة الأولى تشمل فحص مستودع ودليلًا ومخالفة وإعادة تحقق

الاختبار يرافق التنفيذ ونرتب المهام بحسب ما يظهر من عوائق

إثبات القيمة في المرحلة القادمة

نفصل صحة النموذج عن سلوك GitHub وعن فائدة المستخدم



نقارن السماح والمنع المتوقعين بالسلوك الفعلي

مطابقة السماح والمنع في مختبر GitHub مصرح به

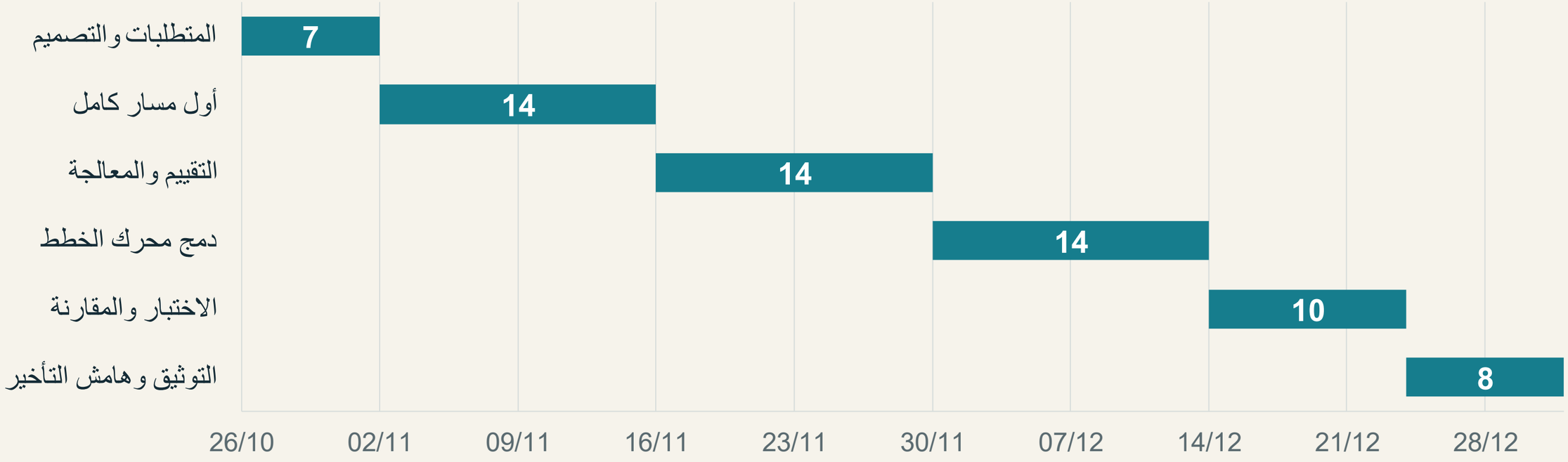
حالات جديدة تشمل التراكب والطبقات الثابتة والبيانات الناقصة

مقارنة بعدد الشروط المتحققة وكلفة التعديل

قياس زمن الوصول إلى خطة صحيحة والأخطاء بتجربة مستقلة

مخطط Gantt

خطة تقديرية من 26 أكتوبر 2026 إلى 1 يناير 2027



الأرقام داخل الأشرطة تمثل أيامًا تقويمية

التسليم المستهدف 1 يناير 2027

المراجع

GitHub Docs

NIST SP 800-53A

Scorecard / Checkov

Legitify / Minder

DefectDojo Open Source

CloudFix · 2026 · Preprint

IAM-PolicyRefiner · OOPSLA 2024

Security Flama · ICSE-SEIP 2024

Towards Automated Continuous Security Compliance · 2024

Revisiting Security Practices for GitHub Actions Workflows · 2025

المراجع الكاملة وروابطها في التقرير والملاحظات؛ سنة النشر تختلف عن فترة البيانات